

# SECURITY TEST STRATEGY

## Browser Security Testing for Healthcare Application

**Document ID:** SEC-BST-HC-001   **Classification:** CONFIDENTIAL   **Version:** 1.0

**Prepared By:** Lead Security Engineering   **Date:** May 2026   **Review Cycle:** Annual / Post Incident

### 1. Executive Summary

This document defines the comprehensive browser security testing strategy for a healthcare application operating within a regulated environment governed by HIPAA, HITECH, HITRUST CSF, and NIST SP 800-66. It is authored from the perspective of an 18-year seasoned lead security engineer with extensive experience securing clinical-grade web applications, Electronic Health Record (EHR) systems, and AI-assisted patient care platforms.

The strategy addresses all ten vulnerabilities as classified by the OWASP Top 10 (2021), incorporates modern browser-layer attack surface assessments, mandates secure handling of Electronic Protected Health Information (ePHI), and extends coverage to emerging risks introduced by AI components and autonomous agents embedded within the application architecture. This document is intended to be formally presented to senior management and adopted as the governing baseline for all security testing activities.

#### INTENT

*This strategy operationalises risk-based, continuous security validation across the full SDLC — from secure design through post-production monitoring — ensuring patient data integrity, regulatory compliance, and system availability.*

## 2. Scope of Testing

### 2.1 In-Scope Components

| Component              | Description                                                       | Browser Attack Surface                                        |
|------------------------|-------------------------------------------------------------------|---------------------------------------------------------------|
| Patient Portal         | Patient-facing web application for scheduling, records, messaging | Login, session tokens, form inputs, file uploads              |
| Clinician Dashboard    | Role-based EHR/EMR UI for clinical staff                          | RBAC enforcement, DOM manipulation, AJAX calls                |
| Telehealth Interface   | WebRTC-based video consultation with media controls               | Media APIs, permissions, signalling channels                  |
| Admin & Audit Console  | System configuration, user management, audit logs                 | Privilege escalation, CSRF, insecure direct object references |
| FHIR/HL7 API Consumer  | Browser-side API calls to FHIR R4 endpoints                       | Token storage, CORS, PKCE OAuth 2.0 flows                     |
| AI Assistant / Chatbot | LLM-powered clinical decision support and patient triage bot      | Prompt injection, data leakage, agent misuse                  |
| Third-Party Widgets    | Lab results, billing modules, pharmacy integrations               | Supply chain, iFrame sandboxing, CSP bypass                   |

### 2.2 Out-of-Scope

- Physical security of server infrastructure and clinical devices
- Non-networked legacy clinical equipment without vendor coordination
- Personal (BYOD) devices not enrolled in corporate MDM
- Source code reverse-engineering of licensed third-party binaries
- Social engineering and phishing simulation campaigns (addressed under separate red-team mandate)

### 2.3 Testing Boundaries & Constraints

- All testing must be conducted in isolated staging environments replicating production topology
- Zero live ePHI exposure during testing — synthetic or Safe Harbor de-identified data only
- Coordinated maintenance windows required for any intrusive or disruptive test activity
- Written Rules of Engagement (RoE) document required prior to penetration testing commencement

## 3. Regulatory & Compliance Framework

| Regulation / Standard    | Applicability to Browser Security Testing                         | Key Controls                      |
|--------------------------|-------------------------------------------------------------------|-----------------------------------|
| HIPAA Security Rule      | Access controls, transmission security, audit controls, integrity | §164.312(a)(1), (c)(1), (e)(1)    |
| HITECH Act               | Breach notification readiness, encryption verification            | Encryption at rest and in transit |
| HITRUST CSF r2           | Pen testing, vulnerability management, secure SDLC alignment      | Control categories 06.i, 06.l     |
| NIST SP 800-66 / CSF 2.0 | Risk-based testing across Identify, Protect,                      | PR.AC, DE.CM, RS.AN controls      |

|                                          |                                                                       |                                            |
|------------------------------------------|-----------------------------------------------------------------------|--------------------------------------------|
|                                          | Detect, Respond                                                       |                                            |
| <b>OWASP ASVS 4.0</b>                    | Application Security Verification Standard for browser-layer controls | Level 2 / Level 3 verification baseline    |
| <b>FDA Cybersecurity Guidance (2023)</b> | Connected device & AI software-as-a-medical-device (SaMD) security    | Premarket cybersecurity, SBOM requirements |
| <b>GDPR / DPDP Act 2023 (India)</b>      | Data subject rights, consent management, cross-border data flows      | Art. 32 GDPR; Sec. 8 DPDP                  |

## 4. OWASP Top 10 — Test Coverage (2021)

All ten OWASP Top 10 (2021) vulnerability categories are mandatorily addressed within this strategy. The following table defines the risk, browser-layer manifestation, testing techniques, and tooling for each category.

### A01:2021 — Broken Access Control

| Attribute                    | Detail                                                                                                                                    |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Healthcare Risk</b>       | Unauthorised access to patient records, clinical orders, or administrative functions; HIPAA minimum-necessary principle violations        |
| <b>Browser Manifestation</b> | Hidden UI elements accessible via direct URL manipulation, IDOR on patient IDs, privilege escalation via manipulated JWT roles            |
| <b>Techniques</b>            | Forced browsing, IDOR enumeration, JWT role tampering, horizontal/vertical privilege escalation, HTTP verb tampering (GET vs POST bypass) |
| <b>Tools</b>                 | Burp Suite Pro (Intruder, Repeater, Authorize extension), OWASP ZAP, Postman, jwt_tool                                                    |

### A02:2021 — Cryptographic Failures

| Attribute                    | Detail                                                                                                                                                                          |
|------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Healthcare Risk</b>       | ePHI transmitted or stored without adequate encryption; violation of HIPAA transmission security requirements (§164.312(e)(1))                                                  |
| <b>Browser Manifestation</b> | HTTP (non-HTTPS) pages, weak TLS cipher suites, sensitive data in localStorage/sessionStorage, unencrypted cookies without Secure flag                                          |
| <b>Techniques</b>            | SSL/TLS configuration audit (TLS 1.0/1.1 deprecation check), certificate chain validation, cookie attribute review, browser DevTools storage inspection, HSTS header validation |
| <b>Tools</b>                 | Testssl.sh, SSLyze, Qualys SSL Labs, Burp Suite (passive scanner), Browser DevTools                                                                                             |

### A03:2021 — Injection

| Attribute                    | Detail                                                                                                                                                    |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Healthcare Risk</b>       | SQL injection in patient search; XSS in clinical note fields to exfiltrate ePHI or hijack clinician sessions; LDAP injection in directory-integrated auth |
| <b>Browser Manifestation</b> | Stored/reflected/DOM-based XSS, SQL/NoSQL injection via form inputs and URL parameters, HTML injection, template injection in clinical workflows          |
| <b>Techniques</b>            | Fuzzing all input vectors, polyglot payloads, blind injection via time-delay, DOM sink analysis, Content-Security-Policy bypass attempts                  |
| <b>Tools</b>                 | SQLmap, Burp Suite (Active Scanner, DOM Invader), OWASP ZAP XSS scanner, DOMPurify bypass test suite, Semgrep (SAST)                                      |

### A04:2021 — Insecure Design

| Attribute              | Detail                                                                                                                                                         |
|------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Healthcare Risk</b> | Flawed clinical workflow design allowing bulk ePHI export, absent rate limiting on prescription submission, or missing re-authentication for high-risk actions |

|                              |                                                                                                                              |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------|
| <b>Browser Manifestation</b> | No multi-factor step-up for sensitive transactions, absence of CAPTCHA/rate limiting on login, insecure password reset flows |
| <b>Techniques</b>            | Threat modelling (STRIDE/DREAD), architectural review, abuse-case analysis, business logic abuse, account enumeration tests  |
| <b>Tools</b>                 | Microsoft Threat Modeling Tool, OWASP Threat Dragon, Burp Suite (business logic tests), manual review                        |

## A05:2021 — Security Misconfiguration

| Attribute                    | Detail                                                                                                                                                             |
|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Healthcare Risk</b>       | Exposed admin panels, verbose error messages revealing stack traces or patient data, misconfigured CORS allowing unauthorised FHIR data reads                      |
| <b>Browser Manifestation</b> | Missing HTTP security headers (CSP, X-Frame-Options, HSTS, X-Content-Type-Options), directory listing, default credentials, XML external entity via browser upload |
| <b>Techniques</b>            | HTTP security header enumeration, CORS misconfiguration probing, error message harvesting, default credential validation, TLS downgrade testing                    |
| <b>Tools</b>                 | SecurityHeaders.com, Nikto, Nmap (web scan), Burp Suite, OWASP ZAP passive rules                                                                                   |

## A06:2021 — Vulnerable and Outdated Components

| Attribute                    | Detail                                                                                                                                                    |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Healthcare Risk</b>       | Exploitation of CVEs in front-end libraries (React, Angular, jQuery) used in patient-facing portals; compromised npm packages in clinical build pipelines |
| <b>Browser Manifestation</b> | Outdated JavaScript libraries served to browsers, known CVE exploitation via client-side script execution, prototype pollution attacks                    |
| <b>Techniques</b>            | Software Composition Analysis (SCA), SBOM generation and review, runtime library fingerprinting, CVE cross-reference against NVD, npm audit               |
| <b>Tools</b>                 | Snyk, OWASP Dependency-Check, Retire.js, npm audit, Trivy (container scanning for bundled assets)                                                         |

## A07:2021 — Identification and Authentication Failures

| Attribute                    | Detail                                                                                                                                                                               |
|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Healthcare Risk</b>       | Credential stuffing attacks targeting clinician logins; session fixation granting unauthorised access to patient records; weak MFA bypass enabling privilege escalation              |
| <b>Browser Manifestation</b> | Session token in URL, non-expiring tokens, weak password policy enforcement, absent MFA step-up, insecure "Remember Me" implementation, PKCE OAuth bypass                            |
| <b>Techniques</b>            | Session fixation testing, credential stuffing simulation, MFA bypass (OTP replay, race condition), OAuth 2.0 flow analysis, concurrent session exploitation, password policy probing |
| <b>Tools</b>                 | Burp Suite (Sequencer, Intruder), Hydra (controlled credential tests), jwt_tool, oauth2-security-testing toolkit                                                                     |

## A08:2021 — Software and Data Integrity Failures

| Attribute             | Detail                                                                                                                                                                        |
|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Healthcare Risk       | Malicious updates delivered to clinical staff browsers; tampered clinical decision data via compromised CDN; insecure CI/CD pipelines enabling supply chain compromise        |
| Browser Manifestation | Missing Subresource Integrity (SRI) on CDN-served scripts, unsigned application updates loaded in-browser, deserialization of untrusted data via browser APIs                 |
| Techniques            | SRI hash validation testing, CDN resource integrity verification, CI/CD pipeline review for integrity checks, JavaScript supply chain analysis, serialization payload fuzzing |
| Tools                 | SRI Hash Generator, Burp Suite, OWASP CycloneDX (SBOM), GitHub Advanced Security, Sigstore/Cosign verification                                                                |

## A09:2021 — Security Logging and Monitoring Failures

| Attribute             | Detail                                                                                                                                                            |
|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Healthcare Risk       | Undetected breach of ePHI; HIPAA audit control failure (§164.312(b)); inability to reconstruct attack timelines for breach notification obligations               |
| Browser Manifestation | Absent client-side error and security event logging, no alerting on repeated failed auth, missing correlation between browser-side anomalies and server-side SIEM |
| Techniques            | Log coverage audits (OWASP Logging Cheat Sheet), alert threshold testing, SIEM correlation rule validation, anomalous access simulation without triggering alerts |
| Tools                 | Splunk / Elastic SIEM, AWS CloudTrail, Azure Sentinel, custom log coverage scripts, Burp Suite (attack replay for alert validation)                               |

## A10:2021 — Server-Side Request Forgery (SSRF)

| Attribute             | Detail                                                                                                                                                                             |
|-----------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Healthcare Risk       | Exploitation of FHIR resource fetch endpoints to pivot to internal clinical systems or cloud metadata services; access to internal diagnostic or imaging servers                   |
| Browser Manifestation | URL parameters used to fetch remote resources (e.g., patient profile images, external lab documents), WebHook configuration endpoints                                              |
| Techniques            | DNS rebinding attacks, SSRF payload injection into URL-accepting inputs (file://, dict://, gopher://, internal RFC-1918 ranges), cloud metadata endpoint probing (169.254.169.254) |
| Tools                 | Burp Suite (Collaborator for SSRF detection), SSRFire, Interactsh, custom SSRF payloads                                                                                            |

## 5. Security Testing Tools Adopted

Tool selection has been made on the basis of industry validation, healthcare-sector suitability, HIPAA-compliant data handling during testing, and CI/CD integration capability. The following tool matrix defines the adopted toolchain:

| Category                     | Tool(s)                                 | Purpose                                                                    | Integration Point                 |
|------------------------------|-----------------------------------------|----------------------------------------------------------------------------|-----------------------------------|
| <b>DAST / Proxy</b>          | Burp Suite Enterprise                   | Active scanning, manual pen testing, business logic testing, API testing   | CI/CD pipeline, pre-release gates |
| <b>DAST (Open Source)</b>    | OWASP ZAP                               | Automated baseline scanning, spider, passive/active rules                  | GitHub Actions, Jenkins           |
| <b>SAST</b>                  | Semgrep, Checkmarx, SonarQube           | Static code analysis for XSS sinks, injection patterns, PHI handling       | PR / commit hooks                 |
| <b>SCA / SBOM</b>            | Snyk, OWASP Dependency-Check, Retire.js | Third-party library CVE detection, SBOM generation                         | Build pipeline, weekly scans      |
| <b>TLS / Crypto Audit</b>    | testssl.sh, SSLyze, Qualys SSL Labs     | Cipher suite validation, certificate chain, HSTS, OCSP stapling            | Pre-deployment, quarterly         |
| <b>API Security</b>          | 42Crunch, Postman, FHIR Validator       | FHIR R4 endpoint security, SMART on FHIR OAuth validation, OpenAPI linting | API gateway, pre-release          |
| <b>Browser DevTools Ext.</b> | Retire.js (ext), Cookie-Editor          | In-browser library enumeration, cookie attribute review                    | Manual testing sessions           |
| <b>Vuln Scanning</b>         | Tenable.io / Nessus, Qualys WAS         | Infrastructure and web application vulnerability enumeration               | Monthly scans, post-deployment    |
| <b>AI / LLM Testing</b>      | Garak, LLM-Fuzzer, PromptBench          | Prompt injection, jailbreak simulation, AI output integrity testing        | Dedicated AI red-team cycle       |
| <b>SIEM / Log Validation</b> | Splunk, Elastic SIEM                    | Audit log coverage validation, alert rule testing                          | Continuous monitoring             |
| <b>SSRF / OOB Detection</b>  | Burp Collaborator, Interactsh           | Out-of-band callback detection for SSRF, blind XSS, XXE                    | Pen test phase                    |

## 6. Security Testing Techniques

---

### 6.1 Reconnaissance & Fingerprinting

- Passive reconnaissance: Shodan, Censys, certificate transparency logs for asset discovery
- Active fingerprinting: HTTP banner grabbing, technology stack identification (Wappalyzer)
- JavaScript source map analysis for exposed logic and API endpoint discovery
- Open-source intelligence (OSINT) review for inadvertently exposed healthcare data

### 6.2 Authentication & Session Testing

- Session token entropy analysis using Burp Sequencer
- Cookie security attribute validation (Secure, HttpOnly, SameSite=Strict/Lax)
- OAuth 2.0 / PKCE flow attack simulation: token leakage, state parameter bypass, redirect\_uri manipulation
- Multi-factor authentication bypass: OTP replay within time window, race condition exploitation
- Concurrent session abuse and session fixation testing
- SAML assertion tampering for SSO-integrated clinical portals

### 6.3 Input Validation & Injection Testing

- Cross-site scripting (XSS): reflected, stored, DOM-based — all clinical form fields, note editors, search bars
- SQL / NoSQL injection via all parameterised entry points including FHIR search parameters
- HTML injection and template injection in dynamically rendered patient communication templates
- File upload security: MIME type bypass, polyglot file attacks, antivirus evasion payloads
- XML external entity (XXE) injection via clinical document import (CDA/CCDA format handling)

### 6.4 Access Control & Privilege Escalation

- Insecure Direct Object Reference (IDOR) enumeration across patient IDs, appointment IDs, lab order IDs
- Horizontal privilege escalation: accessing data belonging to peer patients or clinicians
- Vertical privilege escalation: manipulating JWT role claims to gain administrative access
- Mass assignment testing via API body parameter injection
- Forced browsing to unauthenticated administrative endpoints

### 6.5 Browser & Client-Side Testing

- Content Security Policy (CSP) audit and bypass attempts
- Cross-Origin Resource Sharing (CORS) misconfiguration probing
- Clickjacking via X-Frame-Options and CSP frame-ancestors validation
- Subresource Integrity (SRI) verification for all CDN-loaded assets
- Local/session storage and IndexedDB inspection for improperly stored ePHI or tokens
- Web Messaging (postMessage) attack surface analysis
- Service Worker security review: cache poisoning, background sync abuse

### 6.6 API & Integration Testing

- FHIR R4 endpoint security: SMART on FHIR scope enforcement, unauthorised cross-patient reads
- GraphQL introspection abuse, batch query attacks, deep recursion DoS
- Mass assignment and over-posting via REST API body manipulation



- Rate limiting bypass: IP rotation, header manipulation (X-Forwarded-For spoofing)
- Webhook signature validation and replay attack testing

## 6.7 Infrastructure-Facing Browser Tests

- SSRF via URL-accepting input fields targeting internal RFC-1918 addresses and cloud IMDS (169.254.169.254)
- DNS rebinding attack simulation against single-page application (SPA) architecture
- HTTP request smuggling for healthcare applications behind reverse proxies
- Cache deception and cache poisoning on CDN-fronted patient portal assets

## 7. Special Cases — AI Components & Autonomous Agents

The integration of AI/LLM-powered features into the healthcare application introduces a distinct and high-risk attack surface that demands bespoke testing disciplines beyond traditional OWASP coverage. The following section defines mandatory test coverage for all AI and agent components.

| AI / Agent Risk Category           | Attack Scenario (Healthcare Context)                                                                                        | Test Approach                                                                                                                                        |
|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Direct Prompt Injection</b>     | Malicious patient inputs manipulate AI triage chatbot to recommend incorrect treatments or exfiltrate clinical context      | Fuzz all user-facing AI input fields with adversarial prompt payloads; test instruction override attempts                                            |
| <b>Indirect Prompt Injection</b>   | Malicious content in an ingested lab report or clinical note hijacks AI agent actions downstream                            | Embed adversarial instructions in synthetic test documents; validate agent behaviour with injected content                                           |
| <b>LLM Data Exfiltration</b>       | AI assistant retrieves and leaks ePHI from its context window or RAG data store in response to crafted queries              | Test system prompt leakage, training data extraction attempts, cross-patient context bleed in multi-tenant RAG                                       |
| <b>Insecure Agent Tool Use</b>     | Autonomous agent abuses tool calls (API, file system, email) to exfiltrate data or perform unauthorised actions             | Review all agent-accessible tool definitions; test for SSRF via agent URL-fetching tools; validate tool call authorisation boundaries                |
| <b>AI Jailbreaking</b>             | Adversary bypasses AI safety guardrails to extract restricted clinical guidelines, drug interaction data, or PII            | Apply known jailbreak techniques (DAN, role-play, encoding bypasses); test content filter robustness; use Garak automated scanner                    |
| <b>Excessive Agency / Autonomy</b> | AI agent executes unintended high-risk actions (order cancellations, medication changes) without human-in-the-loop approval | Map all agent capabilities; verify human approval gates exist for irreversible actions; simulate missing confirmation scenarios                      |
| <b>Model Denial of Service</b>     | Computationally expensive prompts degrade AI service availability, impacting clinical decision support uptime               | Submit large context payloads and recursive prompts; validate rate limiting and token budget enforcement on AI endpoints                             |
| <b>RAG Poisoning</b>               | Attacker injects malicious documents into the AI knowledge base to alter clinical recommendations                           | Test document ingestion pipeline security; validate access controls on the vector database; simulate poisoned document injection                     |
| <b>AI Output Integrity</b>         | AI-generated clinical summaries or medication recommendations tampered between generation and display                       | Validate that AI outputs are transmitted over authenticated, integrity-verified channels; test for man-in-the-middle between AI service and frontend |
| <b>Supply Chain (AI Models)</b>    | Compromised or backdoored base model introduces biased or harmful clinical recommendations at scale                         | Verify model provenance, checksums, and signing; review model cards; test for known model backdoor triggers                                          |

**OWASP  
LLM Top  
10**

*All AI testing aligns with the OWASP Top 10 for Large Language Model Applications (v1.1, 2025). Coverage includes LLM01 (Prompt Injection), LLM02 (Insecure Output Handling), LLM06 (Sensitive Information Disclosure), and LLM08 (Excessive Agency).*

## 8. Test Team Capabilities Required

The security testing function must be staffed with multidisciplinary professionals who collectively cover all technical domains addressed by this strategy. The following capability matrix defines the mandatory competencies, certifications, and responsibilities for each role.

| Role                                      | Core Competencies                                                                 | Certifications (Preferred)                                        | Primary Responsibilities                                                      |
|-------------------------------------------|-----------------------------------------------------------------------------------|-------------------------------------------------------------------|-------------------------------------------------------------------------------|
| <b>Lead Security Engineer</b>             | Full-stack offensive security, healthcare compliance, tool orchestration          | OSCP, CISSP, CISM, HITRUST CCSFP                                  | Strategy governance, test planning, risk sign-off, executive reporting        |
| <b>Web Application Penetration Tester</b> | OWASP exploitation, Burp Suite proficiency, API hacking, JavaScript analysis      | OSCP, BSCP (Burp Suite Certified), eWPT                           | Manual pen testing, business logic abuse, OWASP Top 10 coverage               |
| <b>AI / ML Security Specialist</b>        | LLM security, prompt engineering, RAG architecture, agent threat modelling        | OWASP LLM Top 10 familiarity, AI Red Team experience              | AI-specific attack testing, agent boundary validation, model integrity checks |
| <b>DevSecOps / Automation Engineer</b>    | CI/CD security integration, SAST/DAST toolchain management, IaC security          | AWS/Azure Security Specialty, Kubernetes CKS, Terraform expertise | Pipeline integration, SAST/SCA configuration, scan policy management          |
| <b>Healthcare Compliance Analyst</b>      | HIPAA/HITRUST/NIST frameworks, ePHI handling, audit documentation                 | CHPC, HITRUST CCSFP, CIPP/US                                      | Regulatory mapping, evidence collection, BAA review, audit trail validation   |
| <b>Threat Intelligence Analyst</b>        | Healthcare threat landscape, MITRE ATT&CK for Enterprise/Healthcare, IOC analysis | GCTI, eCTHP                                                       | Threat modelling support, adversary simulation scenario design                |
| <b>QA / Security Test Analyst</b>         | Test case design, regression testing, tool operation, defect tracking             | ISTQB Foundation + Security Extension, CompTIA Security+          | Test execution, evidence capture, Jira defect management, retest validation   |

### 8.1 Training & Continuous Development Requirements

- Annual mandatory training: OWASP Top 10 updates, HIPAA Security Rule awareness, AI security fundamentals
- Quarterly hands-on lab practice: HackTheBox Healthcare labs, OWASP WebGoat, custom healthcare test environments
- Annual participation in a recognised CTF or healthcare-focused red team exercise
- Peer review of all penetration test reports prior to management delivery
- Stay current with emerging AI/LLM attack research (OWASP LLM SIG, MITRE ATLAS updates)

## 9. Test Methodology & Phased Approach

| Phase                              | Activities                                                                              | Deliverable                                 | Frequency              | Compliance Link            |
|------------------------------------|-----------------------------------------------------------------------------------------|---------------------------------------------|------------------------|----------------------------|
| <b>1. Scoping &amp; Planning</b>   | Asset inventory, Rules of Engagement, threat model creation, test data provisioning     | Scope doc, RoE agreement, threat register   | Per engagement         | HIPAA §164.308(a)(1)       |
| <b>2. SAST / SCA</b>               | Static code analysis, dependency scanning, SBOM generation, secret detection            | SAST report, SCA findings, SBOM             | Every PR / commit      | HITRUST 06.i               |
| <b>3. DAST / API Testing</b>       | Active scanning, manual API tests, FHIR endpoint security, auth flow validation         | DAST report, API security findings          | Per release            | HIPAA §164.312(e)(1)       |
| <b>4. Penetration Testing</b>      | Full manual pen test, business logic, privilege escalation, OWASP Top 10 coverage       | Executive + technical report, risk register | Quarterly / Bi-annual  | HITRUST 06.I, NIST DE.CM-8 |
| <b>5. AI Red Teaming</b>           | Prompt injection, jailbreak, agent boundary testing, RAG poisoning simulation           | AI threat assessment report                 | Per AI feature release | OWASP LLM Top 10           |
| <b>6. Remediation &amp; Retest</b> | Vulnerability remediation tracking, patch validation, closure evidence                  | Retest report, closure evidence             | SLA-driven (see §10)   | HIPAA §164.308(a)(5)       |
| <b>7. Continuous Monitoring</b>    | WAF rule validation, SIEM alert testing, anomalous access detection, monthly vuln scans | Monthly security dashboard, KPI report      | Ongoing / 24x7         | NIST CSF DE.DP-2           |

## 10. Risk Rating & Remediation SLA

| Severity             | CVSS Range | Clinical Impact                                                        | SLA             | Example                                                        |
|----------------------|------------|------------------------------------------------------------------------|-----------------|----------------------------------------------------------------|
| <b>CRITICAL</b>      | 9.0 – 10.0 | Imminent patient safety risk, ePHI mass breach, clinical system outage | <b>48 hours</b> | Unauthenticated FHIR endpoint exposing full patient record set |
| <b>HIGH</b>          | 7.0 – 8.9  | Privilege escalation, significant ePHI exposure, compliance violation  | <b>7 days</b>   | Broken access control allowing cross-patient record access     |
| <b>MEDIUM</b>        | 4.0 – 6.9  | Partial data exposure, audit log gaps, session management weakness     | <b>14 days</b>  | Reflected XSS in non-authenticated search field                |
| <b>LOW</b>           | 0.1 – 3.9  | Minor information disclosure, configuration hardening opportunity      | <b>30 days</b>  | Missing X-Content-Type-Options response header                 |
| <b>INFORMATIONAL</b> | N/A        | Best practice observation,                                             | 60 days         | Verbose server version                                         |

|  |  |                          |  |                                    |
|--|--|--------------------------|--|------------------------------------|
|  |  | no direct exploitability |  | disclosure in HTTP response header |
|--|--|--------------------------|--|------------------------------------|

**CRITICAL  
NOTE**

*In healthcare, CVSS score alone must NOT determine priority. Clinical patient impact, probability of exploitation, and regulatory penalty exposure must be factored into remediation SLA determination. All Critical findings require immediate escalation to the CISO.*

## 11. Test Environment & Data Governance

| Requirement            | Implementation Standard                                                                                                                            |
|------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| Environment Isolation  | Dedicated security test VPC/VNet, network segmentation via security groups, no production routing. Full production topology mirrored.              |
| Test Data              | Synthetic ePHI or HIPAA-compliant de-identified data per 45 CFR §164.514 Safe Harbor method. Absolutely no live production patient data permitted. |
| Data Masking           | Automated masking applied to: full names, MRNs, SSNs/NHI, DOBs, biometrics, clinical notes, insurance IDs, genomic data, geolocation.              |
| Tester Access Controls | Role-based Just-in-Time (JIT) credentials, mandatory MFA, session recording (Privileged Access Management), least privilege principle enforced.    |
| Audit Logging          | Immutable audit logs for all test actions retained for minimum 6 years per HIPAA requirements. Logs stored in write-once cloud storage.            |
| Environment Teardown   | Automated teardown post-test engagement. Secure data wiping (DoD 5220.22-M standard), certificate rotation, ephemeral credential revocation.       |

## 12. Reporting, Metrics & KPIs

| KPI Metric                                           | Target Threshold    | Reporting Cadence      | Audience                  |
|------------------------------------------------------|---------------------|------------------------|---------------------------|
| Critical / High Vulnerability Density (per KLOC)     | < 0.3               | Monthly                | Engineering Lead          |
| Mean Time to Remediate — Critical                    | < 48 hours          | Real-time alert        | CISO, CTO                 |
| Mean Time to Remediate — High                        | < 7 days            | Weekly                 | Security Lead, CISO       |
| DAST / SAST Coverage (% in-scope assets)             | >= 95%              | Per release            | DevSecOps, QA Lead        |
| OWASP Top 10 Test Case Pass Rate                     | 100%                | Per pen test cycle     | CISO, Compliance          |
| Compliance Control Pass Rate (HIPAA/HITRUST)         | >= 95%              | Quarterly              | Compliance Officer, Legal |
| False Positive Rate (SAST/DAST)                      | < 10%               | Monthly                | Security Engineering      |
| ePHI Exposure Incidents During Testing               | 0 (Zero tolerance)  | Immediate escalation   | CISO, Privacy Officer     |
| AI / LLM Test Coverage (features with AI components) | 100% per AI release | Per AI feature release | CISO, AI Product Lead     |

## 13. Appendices

| Appendix | Content                                                                         |
|----------|---------------------------------------------------------------------------------|
| A        | HIPAA / HITRUST / NIST Control-to-Test Traceability Matrix                      |
| B        | OWASP Top 10 (2021) Detailed Test Case Library — Healthcare Specific            |
| C        | AI / LLM Security Test Case Catalogue (OWASP LLM Top 10 Aligned)                |
| D        | Test Data De-identification Standard Operating Procedure (45 CFR §164.514)      |
| E        | Rules of Engagement (RoE) Template for Penetration Testing Engagements          |
| F        | Security Tool Inventory — Versioning, Licensing & Effectiveness Review Register |
| G        | Clinical Impact & Rollback Plan — Emergency Testing Incident Response Procedure |
| H        | Glossary: ePHI, FHIR, SMART, PKCE, SBOM, CVSS, IDOR, SSRF, RAG, LLM             |

## 14. Document Approval

| Role                                      | Name & Signature | Date |
|-------------------------------------------|------------------|------|
| Chief Information Security Officer (CISO) |                  |      |
| VP Engineering / CTO                      |                  |      |
| Privacy & Compliance Officer              |                  |      |
| Lead Security Engineer                    |                  |      |

*This document is classified CONFIDENTIAL. Distribution is restricted to authorised personnel listed in Section 1 — Document Control. Unauthorised disclosure may constitute a HIPAA compliance violation.*